UNIT 5 · TOPIC 5.2

Protecting Applications and Data: Managerial Controls and Access Controls

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. Which of the following is an example of a managerial control related to application and data security?

- ○ A. Installing a firewall to filter incoming network traffic
- ○ B. Enforcing a data classification policy that labels R&D documents as Confidential
- ○ C. Configuring file permissions using chmod on a Linux server
- ○ D. Deploying antivirus software to detect and quarantine malware

2. Which term correctly describes data that is stored on a server's hard drive and is not currently being transmitted or actively processed?

- ○ A. Data in transit
- ○ B. Data in use
- ○ C. Data in motion
- ○ D. Data at rest

3. An organization requires all developers to complete mandatory security-awareness training before being granted access to production systems. This requirement is best classified as which type of control?

- ○ A. Technical
- ○ B. Physical
- ○ C. Managerial
- ○ D. Compensating

4. A healthcare company classifies patient records as "Restricted" and internal memos as "Internal Use Only." How should the Restricted classification affect the security controls applied to patient records compared to internal memos?

- ○ A. Restricted data requires fewer controls because its label already alerts staff, reducing accidental exposure risk.
- ○ B. Data classification affects only physical security controls, not digital access or encryption requirements.
- ○ C. Both classifications should receive identical controls to ensure consistent and simplified policy enforcement.
- ○ D. Restricted data should receive the strongest protections available, including encryption, strict need-to-know access, and comprehensive audit logging.

5. Vitahealth Solutions needs to restrict the /RandD/Formula directory so that only the head researcher can write to it. Access decisions must be based on defined job roles rather than individual user identities. Which access control model best fits this requirement?

- ○ A. Role-Based Access Control (RBAC)
- ○ B. Mandatory Access Control (MAC)
- ○ C. Discretionary Access Control (DAC)

○ D. Attribute-Based Access Control (ABAC)

6. During a code review, a developer notices that the application transmits patient records to a remote server without any encryption. Which data state is most at risk in this scenario, and which control most directly mitigates the vulnerability?

○ A. Data in transit; TLS/SSL encryption of the communication channel between client and server

○ B. Data in use; Address Space Layout Randomization (ASLR) to protect in-memory processing

○ C. Data at rest; full-disk encryption applied to the server's storage volume

○ D. Data at rest; access control lists (ACLs) restricting who can open the patient records files

7. A defense contractor manages classified project documents that must be accessible only to personnel with the required government clearance level, regardless of who created or owns the documents. The security team is evaluating DAC, RBAC, and MAC. Which model is most appropriate, and what is the strongest justification for that choice?

○ A. DAC, it gives document owners flexible control, allowing project teams to manage their own permissions without bottlenecks.

○ B. MAC, access is determined by centrally enforced classification labels and clearance levels that cannot be overridden by resource owners.

○ C. RBAC, it maps access to job roles, ensuring that clearance levels are enforced at an organizational level through role assignments.

○ D. ABAC, it can combine multiple attributes including clearance level, project code, and time-of-day to grant access with maximum precision.

8. A CISO reviews a data classification policy and finds that Public, Internal, and Confidential data all receive the same encryption standards and audit logging requirements. What is the primary security risk of this approach, and what corrective action is recommended?

○ A. There is no significant risk, uniform controls simplify compliance and reduce the chance of configuration errors across tiers.

○ B. Confidential data is under-protected because controls are calibrated to the lowest tier; the recommended fix is tiered controls scaled to classification level and breach impact.

○ C. Public data is over-protected, wasting IT resources; the fix is to remove controls from Public data while keeping them on Confidential data.

○ D. The classification framework should be abandoned entirely; uniform encryption of all data is sufficient without tiered labels.

9. Vitahealth Solutions' security team proposes four managerial controls: (1) a data classification policy, (2) acceptable use agreements signed by all staff, (3) mandatory quarterly security training, and (4) a documented incident response plan. A security auditor argues that these controls are insufficient on their own. Which evaluation of the auditor's position is most accurate?

○ A. The auditor is incorrect, well-designed managerial controls are sufficient; adding technical controls introduces unnecessary operational complexity.

○ B. The auditor is partially correct, managerial controls only serve regulatory compliance purposes, and technical controls are responsible for all actual security enforcement.

○ C. The auditor is correct, managerial controls establish policy intent but require human compliance; without technical enforcement mechanisms, a determined insider or external attacker can bypass them.

○ D. The auditor is incorrect, managerial controls primarily serve to limit legal liability, which is the principal goal of an organizational security program.

10. Which Linux command is used to change the access permissions of a file or directory?

- ○ A. chown
- ○ B. chgrp
- ○ C. chmod
- ○ D. ls -l

11. A Linux file has the permission string rwxr-x---. What level of access does a user who belongs to the file's group have?

- ○ A. Read and execute only
- ○ B. Read, write, and execute
- ○ C. Read only
- ○ D. No access

12. Which of the following is a technical control that directly enforces a data access restriction on a Linux system?

- ○ A. Using chmod to restrict file access to authorized users only
- ○ B. Conducting annual employee security awareness training
- ○ C. Publishing a data classification policy document
- ○ D. Writing and distributing an incident response plan

13. A security administrator needs to set permissions on /RandD/Research so that the R&D group has full access (read, write, and execute) and all other users have no access. Which chmod command correctly implements this?

- ○ A. chmod 770 /RandD/Research
- ○ B. chmod 750 /RandD/Research
- ○ C. chmod 700 /RandD/Research
- ○ D. chmod 755 /RandD/Research

14. In the Vitahealth scenario, the /RandD/Formula directory must allow the head researcher (owner) full access, the R&D team (group) read and execute access only, and all other users no access. Which numeric chmod value correctly implements this policy?

- ○ A. chmod 754 /RandD/Formula
- ○ B. chmod 740 /RandD/Formula
- ○ C. chmod 750 /RandD/Formula
- ○ D. chmod 700 /RandD/Formula

15. A security analyst is implementing RBAC for a web application. Users assigned the "Auditor" role must be able to read audit log files but not modify or execute them. The audit logs are owned by root and associated with the "rnd" group. Which chmod value, applied to the audit log file, best enforces the Auditor group's read-only requirement if Auditors are assigned their own "auditor" group?

- ○ A. chmod 640 audit.log
- ○ B. chmod 770 audit.log
- ○ C. chmod 644 audit.log
- ○ D. chmod 600 audit.log

16. A security auditor examines the Vitahealth server and finds the following permissions:
/RandD, chmod 755
/RandD/Research, chmod 770
/RandD/Formula, chmod 750

Vitahealth policy specifies: (1) R&D team has full rwx access to /RandD; other users may read and access it. (2) Only R&D members have any access to /RandD/Research. (3) Only the head researcher has rwx on /RandD/Formula; R&D team has r-x; all others have no access.

Which directory's permissions violate the policy, and why?

- ○ A. /RandD/Formula only, chmod 750 grants the R&D group too many permissions beyond what policy allows.
- ○ B. /RandD/Research only, chmod 770 incorrectly allows others to access and write to the directory.
- ○ C. /RandD only, the R&D group is assigned r-x (5) but policy requires full rwx (7) for group; correct value is 775.
- ○ D. All three directories are correctly configured per policy.

17. A junior administrator secures a sensitive application configuration file with the command: chmod 646 config.conf. A senior security engineer immediately flags this as a critical misconfiguration. Which specific problem does the senior engineer identify?

- ○ A. The owner cannot read the configuration file.
- ○ B. The group has write access, allowing group members to alter the configuration.
- ○ C. The execute bit is set for the owner, allowing arbitrary code execution from the config file.
- ○ D. Others have read and write access, meaning any user on the system can read and modify the file.

18. Vitahealth Solutions is transitioning from DAC to RBAC on its R&D Linux server. Three roles are defined: Head Researcher, R&D Member, and Auditor. Auditors must be able to read all R&D directories for compliance reviews but must not have write access. Existing R&D member permissions must remain unchanged. Which implementation approach correctly realizes this RBAC structure on Linux?

- ○ A. Create an "auditor" Linux group; use chmod o+r on /RandD and all subdirectories to grant global read access to everyone including auditors.
- ○ B. Create an "auditor" Linux group; use chmod and POSIX ACLs (setfacl) to grant the auditor group read-only access to each R&D directory without modifying existing rnd group permissions.
- ○ C. Add all auditor users directly to the existing "rnd" group so they inherit current R&D permissions; restrict them further only at the application layer.
- ○ D. Temporarily set all R&D directories to chmod 777 before each audit and revert them manually afterward.